

DEMO.CSITE.REC.05/31.01.015/2025-26

Cyber Security Framework for Regulated Entities

In exercise of the powers conferred under the applicable statute, the following directions are issued. These directions shall come into force with immediate effect and shall supersede earlier instructions on the subject to the extent that they are inconsistent.

1. Board approved policy

Every regulated entity shall put in place a cyber security policy approved by its board, distinct from the broader information technology policy, and shall review it at least once every financial year.

2. Incident reporting

All unusual cyber security incidents, whether or not they resulted in loss, shall be reported within six hours of detection. The report shall include the nature of the incident, the systems affected, and the containment measures taken.

3. Security operations centre

Regulated entities shall establish a security operations centre providing continuous surveillance. The centre shall be operational at all times and shall maintain logs for a period of not less than one year.

4. Vulnerability assessment

A vulnerability assessment and penetration test shall be conducted at least once every six months for critical systems, and after every material change to the application architecture.

5. Access control

Privileged access shall be granted on the principle of least privilege and shall be reviewed once every quarter. Shared administrative credentials are prohibited.

6. Vendor risk

Where information technology services are outsourced, the regulated entity shall remain responsible for the confidentiality and integrity of customer data. The outsourcing agreement shall provide for the right to audit the vendor.

7. Business continuity

A disaster recovery drill shall be conducted at least once every six months, and the recovery time objective and recovery point objective shall be documented and tested.